Objective 3.1 — Conduct vulnerability discovery using various techniques

A **match-the-scan-and-tool-to-the-scenario** objective. The heavily-tested splits: **DAST vs SAST vs IAST vs SCA** (where in the SDLC + what vantage point), **authenticated vs unauthenticated** (accuracy vs attacker-view), and **ICS = passive/manual**. Domain 3.0 = 17%% of the exam.

1 · Scan map — scan types by target layer

Application scans
SAST · DAST · IAST · SCA · SAST › IaC · Source code analysis · Mobile scan

Network scans
TCP scan · UDP scan · Stealth scans

Host & identity
Host-based scan · Authenticated vs unauthenticated · Secrets scanning

Container & cloud
Container scan · Sidecar scan

Wireless scans
SSID scanning · Channel scanning · Signal strength scanning

ICS assessment
Manual assessment · Port mirroring (SPAN)

The application-scan timeline (earlier → later in the SDLC):

SAST	SCA	DAST	IAST
static · needs source	dependencies	runtime · external	runtime · agent

2 · Scan-type cards

Every 3.1 scan type — what it is, high-yield facts, exam tell. Grouped by target layer.

APPLICATION SCANS

SAST [white-box · static]

Analyzes source, bytecode, or binaries **without running** the app.

- Requires **source code**; gives file + line-level findings
- Earliest in the SDLC — catches flaws before deployment
- Finds injection, hardcoded creds, weak crypto, buffer overflows

EXAM TELL "find vulns before running / has source code / early in the SDLC" -> SAST.

DAST [black-box · runtime]

Tests a **running** app from the outside, like an external attacker.

- **No source code** needed; sends crafted inputs, observes responses
- Finds SQLi, XSS, auth flaws, SSRF, directory traversal
- Can throw false positives; tools: Burp Suite, OWASP ZAP

EXAM TELL "running app / external attacker / no source access" -> DAST.

IAST [hybrid · agent]

Instruments the app **internally during execution** via an agent/sensor.

- Hybrid of SAST + DAST; watches from **inside** while the app runs
- Pinpoints the **exact code location** of a vulnerability
- Fewer false positives; strong fit for CI/CD pipelines

EXAM TELL "agent inside the running app / exact code line" -> IAST.

SCA [dependencies]

Inventories third-party / open-source components and maps them to known CVEs.

- Dependency inventory + **transitive** dependency analysis
- License compliance; Equifax/Apache Struts is the classic case
- Tools: OWASP Dependency-Check, Grype, Trivy

EXAM TELL "third-party libraries / open-source dependencies" -> SCA.

SAST › IaC [cloud templates]

SAST applied to **infrastructure-as-code** templates (Terraform/CloudFormation/Ansible).

- Catches misconfig **before deploy** — one bad template scales everywhere
- Finds public S3, permissive security groups, disabled logging, hardcoded creds
- Tools: TFLint, Checkov, Terrascan

EXAM TELL "Terraform/CloudFormation misconfig before deploy" -> IaC scanning (a form of SAST).

Source code analysis [white-box]

Direct examination of application code for insecure patterns — the core of SAST.

- Unsanitized input, hardcoded secrets, insecure calls, weak crypto
- Manual review or automated (SonarQube)

EXAM TELL "review the code itself for insecure patterns" -> source code analysis.

Mobile scan [APK / IPA]

Evaluates Android/iOS apps — combines static and dynamic testing.

- **Static**: decompile APK/IPA (MobSF, JADX) — hardcoded keys, permissions
- **Dynamic**: emulator + intercept traffic (Burp, Frida)
- Finds insecure storage, exported components, cert-pinning gaps

EXAM TELL "decompile the APK / mobile app / hardcoded key in the app" -> mobile scan.

NETWORK SCANS

TCP scan [handshake]

Uses the TCP three-way handshake to determine port states.

- **SYN** half-open (root, stealthy) · **Connect** (no root, logged) · FIN/NULL/Xmas (probe filters)
- States: open / closed / filtered / **open|filtered**

EXAM TELL "port scan / handshake / find open ports" -> TCP scan.

UDP scan [connectionless]

Connectionless probing — slower and more ambiguous than TCP.

- Closed -> **ICMP Port Unreachable**; open -> often no reply (open|filtered)
- Essential for DNS 53, **SNMP 161**, DHCP 67/68, TFTP 69

EXAM TELL "DNS/SNMP / connectionless / ICMP unreachable" -> UDP scan.

Stealth scans [evasion]

Techniques to reduce IDS/IPS detection — "less detectable, not invisible."

- SYN, NULL, FIN, Xmas; **fragmentation**; **idle/zombie** hides your source IP
- Timing templates `-T0`..`-T5` slow scans to dodge rate-based detection

EXAM TELL "avoid IDS / reduce detection / zombie host" -> stealth scan.

HOST & IDENTITY

Host-based scan [system-deep]

Drills into one system's config, patches, services, and permissions.

- Patch levels, insecure defaults, running services, SUID/SGID, registry
- Deepest single-system visibility (esp. when credentialed)
- A compromised host becomes the **pivot point**

EXAM TELL "deep single-system view / patch + config audit" -> host-based scan.

Authenticated vs unauthenticated [credentials]

Whether the scanner logs in — the biggest accuracy lever you control.

- **Authenticated** = credentials, most accurate, sees patches/config, fewer FPs (gold standard)
- **Unauthenticated** = external attacker view, banners only, more FPs/FNs
- Use **read-only least-privilege** creds — not domain admin

EXAM TELL "most accurate results" -> authenticated; "black-box test" -> unauthenticated.

Secrets scanning [creds in code]

Finds exposed keys, passwords, and tokens in code, repos, images, and configs.

- API keys, passwords, private keys, session tokens, connection strings
- **TruffleHog** scans full **Git history** (pattern + entropy)
- Often the **fastest path** to privilege escalation / cloud access

EXAM TELL "hardcoded key / .env file / secret in Git history" -> secrets scanning (TruffleHog).

CONTAINER & CLOUD

Container scan [images + runtime]

Scans container images, running containers, and orchestration config.

- Vulnerable **base images**, exposed secrets, root/over-permissioned containers
- Image (pre-deploy) + runtime + config vs **CIS Docker Benchmark**
- Tools: Trivy, Grype

EXAM TELL "container image CVEs / Docker misconfig" -> container scan.

Sidecar scan [pod neighbor]

Targets the **secondary** container sharing a Kubernetes pod with the primary.

- Sidecars have intimate access to the primary (filesystem, network, processes)
- A compromised sidecar -> pivot to the primary container / other pods
- Often over-permissioned or unpatched — a specific attack vector

EXAM TELL "secondary container in the pod / sidecar" -> sidecar scan.

WIRELESS SCANS

SSID scanning [network names]

Maps nearby networks, their encryption, and hidden/rogue APs.

- SSID + BSSID; WPA2/WPA3/WEP/Open
- **Hidden SSID is not a control** — it leaks in probe requests
- Detects rogue access points; tools: Aircrack-ng, Kismet, InSSIDer

EXAM TELL "network names/encryption / hidden SSID / rogue AP" -> SSID scanning.

Channel scanning [frequency]

Examines which RF channels are in use and how they overlap.

- Congestion/overlap (mismanagement), rogue APs on unexpected channels
- Interference/jamming patterns; evil twin on the same channel

EXAM TELL "channel congestion/overlap / which channel" -> channel scanning.

Signal strength scanning [RSSI]

Measures RSSI to physically locate access points.

- Locate APs in a site survey; an unexpected strong signal = possible **rogue/evil twin**
- **Wardriving** = RSSI + GPS mapping; tools: InSSIDer, WiGLE, Kismet

EXAM TELL "physically locate the AP / RSSI / wardriving" -> signal strength scanning.

ICS ASSESSMENT

Manual assessment [passive · no scan]

Config, physical, protocol, and doc review + interviews — **no probing**.

- ICS is fragile: one probe can fault/halt a **PLC** and disrupt a physical process
- Review Modbus/DNP3/PROFINET (many have no auth or encryption)
- **Purdue Model** levels 0-5; **availability > confidentiality**

EXAM TELL "assess ICS/SCADA/PLC without disruption" -> manual assessment.

Port mirroring (SPAN) [passive capture]

A switch copies live traffic to a monitor port — purely passive capture.

- **Zero traffic sent** to ICS devices — the safest method
- Full visibility: protocols, cleartext creds, replay opportunities
- Analyze with Wireshark (industrial dissectors), tcpdump, Scapy

EXAM TELL "capture ICS traffic without introducing traffic / SPAN" -> port mirroring.

3 · Tools

The nine official 3.1 tools, colored by the layer they serve.

Nikto

Open-source **web server** scanner.

- Checks 6,000+ dangerous files, 1,250+ server versions, bad HTTP methods, missing headers
- **Not stealthy** — large footprint / heavy logging
- Server-level issues, not deep application logic

EXAM TELL "quick web-server vuln scan, stealth not required" -> Nikto.

Greenbone / OpenVAS

Open-source comprehensive vulnerability scanner.

- 50,000+ tests, daily updates; auth + unauth; network/host/web
- CVSS-scored reports; compliance scans
- The **free alternative to Nessus**

EXAM TELL "free / open-source comprehensive scanner" -> OpenVAS.

Tenable Nessus

Commercial vulnerability scanner (industry standard).

- 100,000+ plugins; auth + unauth; compliance (PCI/CIS/HIPAA); agent-based
- Scan templates; free for home = Nessus Essentials
- Keep plugins updated or you get false negatives

EXAM TELL "commercial comprehensive scanner / plugins" -> Nessus.

TruffleHog

Secrets discovery tool for code repositories.

- Scans the **full Git commit history**, not just current code
- Pattern matching + **entropy analysis**
- Finds AWS keys, tokens, private keys, connection strings

EXAM TELL "exposed secrets in a repo / Git history" -> TruffleHog.

BloodHound

Active Directory attack-path analysis (graph theory).

- **SharpHound** collects the data; BloodHound (Neo4j) visualizes it
- Shortest path to Domain Admin; Kerberoastable, AS-REP, **DCSync**, ACL paths
- Run after an AD foothold to plan escalation / lateral movement

EXAM TELL "AD privilege-escalation path / attack graph" -> BloodHound.

PowerSploit

PowerShell post-exploitation toolkit for Windows.

- **PowerView** (AD enum), **PowerUp** (privesc), Invoke-Mimikatz (cred dump), Get-GPPPassword
- In-memory / **fileless**, living off the land
- Modern EDR detects it — obfuscation often needed

EXAM TELL "PowerShell AD enumeration / PowerView" -> PowerSploit.

Grype

Container + filesystem vulnerability scanner (Anchore).

- Scans images, filesystems, and SBOMs; inventories packages -> CVEs
- Vulnerability-focused (narrower than Trivy)

EXAM TELL "container/package CVEs / SBOM vulnerability scan" -> Grype.

Trivy

All-in-one open-source scanner (Aqua Security).

- Containers **+** filesystems **+** Git **+** IaC **+** Kubernetes **+** secrets + SBOM
- The most versatile container tool on the exam
- Can replace the deprecated Kube-hunter for K8s

EXAM TELL "one tool for containers AND IaC AND secrets" -> Trivy.

Kube-hunter

Kubernetes security assessment tool (Aqua).

- Finds exposed API server / dashboard / etcd / Kubelet, RBAC misconfig, container escape
- Runs from outside (remote) or inside a pod (in-cluster)
- **Deprecated** — Trivy is the modern replacement

EXAM TELL "scan a Kubernetes cluster" -> Kube-hunter (deprecated, know it anyway).

4 · Critical comparisons

The distinctions the exam turns on — the accent line names the split.

DAST vs SAST vs IAST vs SCA — Same goal — find app vulnerabilities — at different SDLC stages and vantage points.

SAST `[white-box]`
Static, needs source, earliest — code-level flaws.

SCA `[dependencies]`
Third-party libraries mapped to known CVEs.

DAST `[black-box]`
Runtime, external, no source — attacker's view.

IAST `[hybrid]`
Runtime + internal agent — exact code location.

Authenticated vs Unauthenticated — The single biggest accuracy lever on a vuln scan.

Authenticated `[credentialed]`
Logs in — **most accurate**, sees patches/config, fewer FPs (white-box).

Unauthenticated `[external]`
Attacker's outside view — banners only, more FPs/FNs (black-box).

Nessus vs OpenVAS — Both comprehensive vuln scanners — split by licensing.

Nessus `[commercial]`
Tenable; **100,000+ plugins**; more support (free = Essentials).

OpenVAS `[open-source]`
Greenbone; **50,000+ tests**; fully free.

Trivy vs Grype vs Kube-hunter — The container-ecosystem tools — split by breadth.

Trivy `[all-in-one]`
Containers + IaC + secrets + K8s + filesystem.

Grype `[vuln/SBOM]`
Containers + filesystem package CVEs.

Kube-hunter `[K8s only]`
Kubernetes cluster weaknesses (deprecated).

Nikto vs Nessus/OpenVAS — Both find vulns — split by scope.

Nikto `[web server]`
Web-server-specific, fast, noisy.

Nessus / OpenVAS `[broad]`
Network + host + web, comprehensive.

BloodHound vs PowerSploit — Both work Active Directory — split by method.

BloodHound `[graph]`
Graphical **attack-path** analysis (needs SharpHound).

PowerSploit `[PowerShell]`
Manual AD **enum + privesc + cred dump** (PowerView).

Manual assessment vs Port mirroring — Both ICS-safe and passive — split by data source.

Manual assessment `[review]`
Configs, docs, protocols, interviews — **no traffic at all**.

Port mirroring `[capture]`
Passive copy of live traffic (SPAN) -> Wireshark.

Application-scan matrix

SCAN	NEEDS SOURCE?	RUNNING APP?	KEY FOCUS
DAST	No	Yes	Runtime vulns from outside
IAST	No (benefits)	Yes	Runtime vulns from inside
SCA	No	No	Third-party dependency vulns
SAST	Yes	No	Code-level weaknesses pre-run
Mobile	Both	Both	Mobile-specific attack surface

5 · Scenario decoder — clue → scan type → tool

How the exam phrases it. Match the clue, name the scan and the tool.

CLUE IN THE QUESTION	SCAN TYPE	KEY TOOL
"find vulns before running, has source"	SAST	SonarQube / manual review
"simulate external attacker on a live app"	DAST	Burp Suite / OWASP ZAP
"agent pinpoints the exact vulnerable line"	IAST	(instrumented runtime)
"open-source / third-party library CVEs"	SCA	Grype / Trivy / Dependency-Check
"Terraform/CloudFormation misconfig pre-deploy"	IaC scanning (SAST)	Checkov / Terrascan
"decompile an APK / mobile app"	Mobile scan	MobSF / Frida / Drozer
"container image vulnerable packages"	Container scan	Trivy / Grype
"one tool: containers + IaC + secrets"	Container scan	Trivy
"scan a Kubernetes cluster"	Container scan	Kube-hunter (or Trivy)
"AD privilege-escalation paths"	Host-based (AD)	BloodHound (+ SharpHound)
"AD enumeration via PowerShell"	Host-based (AD)	PowerSploit / PowerView
"network infrastructure ports/services"	Network scan	Nmap / Nessus / OpenVAS
"secrets in a code repo / Git history"	Secrets scanning	TruffleHog
"wireless networks / rogue AP"	Wireless scan	Aircrack-ng / Kismet / InSSIDer
"ICS / SCADA without disruption"	Manual assessment + port mirroring	Wireshark / tcpdump
"most accurate / complete results"	Authenticated scan	Nessus / OpenVAS (credentialed)
"black-box, no credentials"	Unauthenticated scan	—
"free comprehensive vuln scanner"	Network/host scan	OpenVAS
"commercial comprehensive vuln scanner"	Network/host scan	Nessus
"quick web-server vuln scan, noisy OK"	Application scan	Nikto

6 · Which-scan quiz (answer key included)

Scenario in, scan-type-or-tool out — weighted toward the confusable splits.

Q01

A developer wants to find security flaws early, before the application is ever run, and has full access to the source code.

Which scan type?

SAST Application

WHY SAST is static white-box analysis of source/bytecode without executing it — the earliest-SDLC option and the one that needs source code.

Q02

A tester must simulate an external attacker against a live web application, with no access to its source code.

Which scan type?

DAST Application

WHY DAST is black-box runtime testing from the outside — no source needed. SAST would need code; IAST would need an internal agent.

Q03

An embedded agent inside the running application reports the exact file and line where a vulnerability triggers.

Which scan type?

IAST Application

WHY IAST instruments the app internally during execution, combining SAST+DAST to pinpoint the exact code location with few false positives.

Q04

An application is built largely from open-source libraries; the team needs to know which of those have known CVEs.

Which scan type?

SCA Application

WHY Software Composition Analysis inventories third-party/transitive dependencies and maps them to known CVEs (the Apache Struts/Equifax case).

Q05

Which vulnerability scan configuration produces the most accurate and complete results?

Which choice?

Authenticated (credentialed) scan Host

WHY Logging in lets the scanner read patch levels and configs, drastically cutting false positives/negatives. Use read-only least-privilege creds.

Q06

The engagement is strictly black-box with no credentials provided to the tester.

Which scan type fits?

Unauthenticated scan Host

WHY Unauthenticated scanning matches the external-attacker perspective of a black-box test; credentialed results would be out of scope.

Q07

A tester must assess a SCADA network with legacy PLCs that can fault if they receive unexpected packets.

Which approach?

Manual assessment + port mirroring (passive) ICS

WHY ICS prioritizes availability; use low-impact manual review and passive traffic capture. Aggressive automated scanning is the wrong answer.

Q08

You need to observe ICS traffic while introducing zero new traffic onto the network.

Which technique?

Port mirroring (SPAN) ICS

WHY Port mirroring copies existing traffic to a monitor port — the safest, fully passive ICS method; analyze it in Wireshark.

Q09

A Docker image pulled from a registry must be checked for vulnerable OS packages before deployment.

Which tool?

Trivy or Grype Container

WHY Both scan container images for vulnerable packages. Grype is vuln/SBOM-focused; Trivy also covers IaC and secrets.

Q10

The team wants a single tool that scans containers, Infrastructure-as-Code, AND secrets.

Which tool?

Trivy Container

WHY Trivy is the most versatile — containers, filesystems, Git, IaC, Kubernetes, and secrets in one tool; it can even replace Kube-hunter.

Q11

An AWS key was committed to a repo and then removed in the next commit.

Which tool still finds it, and why?

TruffleHog (scans full Git history) Host

WHY TruffleHog scans the entire commit history with pattern matching + entropy, so secrets that were "deleted" are still discoverable.

Q12

After gaining a foothold in a Windows domain, the tester wants to map the shortest path to Domain Admin.

Which tool?

BloodHound (SharpHound collects) Host

WHY BloodHound graphs AD relationships to reveal escalation paths; SharpHound is the collector that feeds it the data.

Q13

A quick vulnerability scan of a web server is needed and stealth is not a concern.

Which tool?

Nikto Application

WHY Nikto is the dedicated web-server scanner (6,000+ dangerous-file checks). It is fast but noisy — fine when stealth is not required.

Q14

The client needs a comprehensive vulnerability scanner but requires a free, open-source option.

Which tool?

Greenbone / OpenVAS Network

WHY OpenVAS is the free/open-source comprehensive scanner (50,000+ tests) — the open alternative to the commercial Nessus.

Q15

A wireless network is configured with a hidden SSID. Is that an effective security control?

What should the tester conclude?

No — hidden SSIDs are discoverable Wireless

WHY The SSID still leaks in probe requests and can be recovered by passive monitoring; hiding it is not a real control.

7 · Keyword → meaning reference

KEYWORD	WHAT IT MEANS FOR THE EXAM
black-box	No prior knowledge -> unauthenticated / DAST
white-box	Full knowledge -> authenticated / SAST
DAST	Runtime, external, no source needed
SAST	Static, needs source, pre-deployment
IAST	Runtime + internal agent, exact code location
SCA	Third-party / open-source dependency CVEs
IaC	Cloud templates (Terraform/CFN) scanned with SAST
source code analysis	Direct code review (core of SAST)
mobile scan	APK/IPA decompile + dynamic testing
sidecar	Secondary K8s container with access to primary
SYN scan	Half-open, stealthy, requires root
connect scan	Full handshake, no root, more logged
NULL/FIN/Xmas	Flag-based stealth probes
open|filtered	Ambiguous port state (common on UDP)
UDP scan	Connectionless, slower, DNS/SNMP
stealth scan	Reduces detection, not invisible
idle / zombie scan	Hides the scanner's source IP
host-based scan	Deep single-system config/patch view
authenticated scan	Credentialed, most accurate
unauthenticated scan	External attacker view, less detail
least privilege / read-only	Scanning-account principle
secrets scanning	API keys/passwords/tokens in code
TruffleHog	Git-history secrets (pattern + entropy)
container scan	Images/runtime/config for CVEs
port mirroring / SPAN	Passive traffic copy, zero ICS impact
manual assessment	Low-impact ICS review, no scanning
Purdue Model	ICS network segmentation levels 0-5
availability	ICS priority (over confidentiality)
SSID / BSSID	Wireless network name / AP MAC
RSSI	Signal strength -> locate/rogue AP
BloodHound	AD attack-path graph (SharpHound collects)
PowerView	AD enum module of PowerSploit
Nikto	Web-server scanner, not stealthy
OpenVAS	Free comprehensive scanner (vs Nessus)
Nessus	Commercial, 100,000+ plugins
Trivy	All-in-one container/IaC/secrets scanner
Grype	Container/filesystem package CVEs (SBOM)
Kube-hunter	Kubernetes scanner (deprecated)